

Manual 12 - CCPA / CPRA California Privacy Controlled Implementation

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: 93d5831ff3bd2349eb4973e3a77a8bd3d301c1d4 | Language: en | California privacy legal and phased-date boundaries retained.

Legal and assurance boundary: This manual operationalizes California privacy practices but does not provide organization-specific legal advice, determine applicability or exemptions, establish risk-assessment sufficiency, decide cybersecurity-audit scope, determine ADMT coverage, establish liability, or guarantee CCPA/CPRA compliance. Current and phased obligations must be applied according to their effective dates and competent human legal/privacy judgment.

Implementation paths

Manual 12 — CCPA / CPRA Implementation Paths

These paths scale implementation depth without changing the underlying legal obligations. Applicability and legal interpretation remain organization-specific and require competent human judgment.

Path A — Essential

Designed for smaller or less complex organizations whose California privacy obligations can be operated through a comparatively bounded data environment.

Minimum operating package:

- applicability and threshold analysis;
- role inventory for business, service provider, contractor, and third-party relationships;
- personal-information and sensitive-PI inventory;
- notice at collection and privacy-policy controls;
- consumer-rights intake, verification, response, timing, and evidence;
- sale/sharing and opt-out preference signal handling;
- retention/deletion rules;
- contract controls for service providers/contractors;
- risk-assessment screening;
- reasonable-security baseline;
- evidence register and periodic management review.

Path B — Structured

Designed for organizations with multiple business units, websites/apps, advertising ecosystems, suppliers, data products, or higher-volume consumer requests.

Add:

- enterprise data-flow and purpose inventory;
- automated opt-out preference signal testing;
- sensitive-PI use/disclosure controls;
- minors/opt-in workflow where applicable;
- financial-incentive governance;
- formal service-provider/contractor due diligence;
- documented risk-assessment methodology and review board;
- cybersecurity-audit readiness planning;
- ADMT inventory and applicability screening;
- request-quality metrics and exception review;
- data retention/deletion validation;
- privacy engineering integration into change management;

- enforcement-response evidence package.

Path C — Enhanced

Designed for large, data-intensive, advertising-heavy, AI-enabled, multinational, or highly regulated organizations.

Add:

- enterprise California privacy control framework;
- automated data discovery with human validation;
- continuous preference-signal monitoring;
- advanced advertising/measurement/identity-resolution governance;
- centralized sensitive-PI controls;
- formal risk-assessment portfolio governance;
- independent challenge for material risk assessments;
- cybersecurity-audit evidence architecture and phased-deadline readiness;
- ADMT significant-decision governance, pre-use notices, access/opt-out operations, and 2027 readiness;
- data-broker/DROP applicability screening where relevant;
- continuous third-party and data-flow monitoring;
- executive privacy metrics and corrective-action tracking;
- crosswalks to GDPR, NIST Privacy Framework, ISO/IEC 27701, ISO/IEC 27001, and sector requirements where useful.

Seven-gate California privacy lifecycle

Manual 12 memory graphic 1

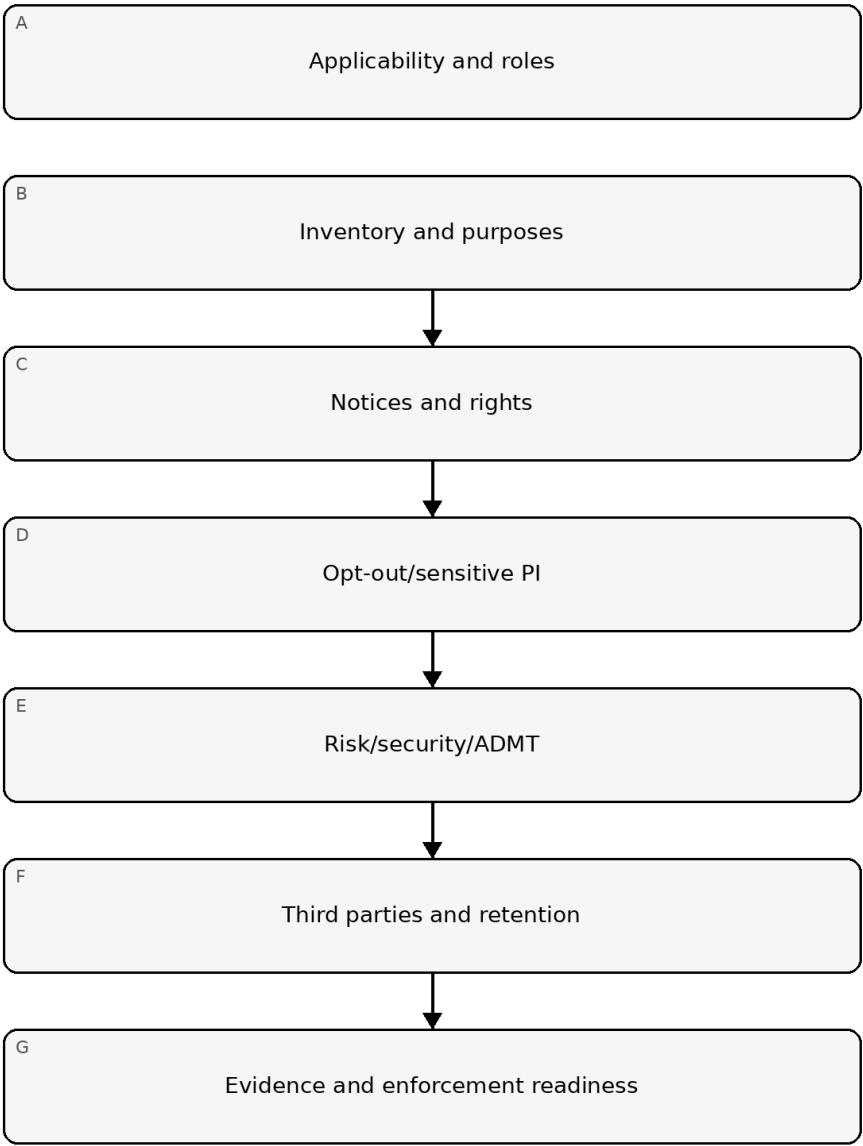


Figure 1. California privacy implementation memory graphic

Accessible explanation: The California privacy lifecycle begins with applicability and role analysis, then maps data and purposes, operationalizes notices and rights, handles opt-out and sensitive-PI controls, evaluates risk/security/ADMT obligations, governs downstream parties and retention, and maintains evidence for review and enforcement readiness.

Consumer-rights routing

Manual 12 memory graphic 2

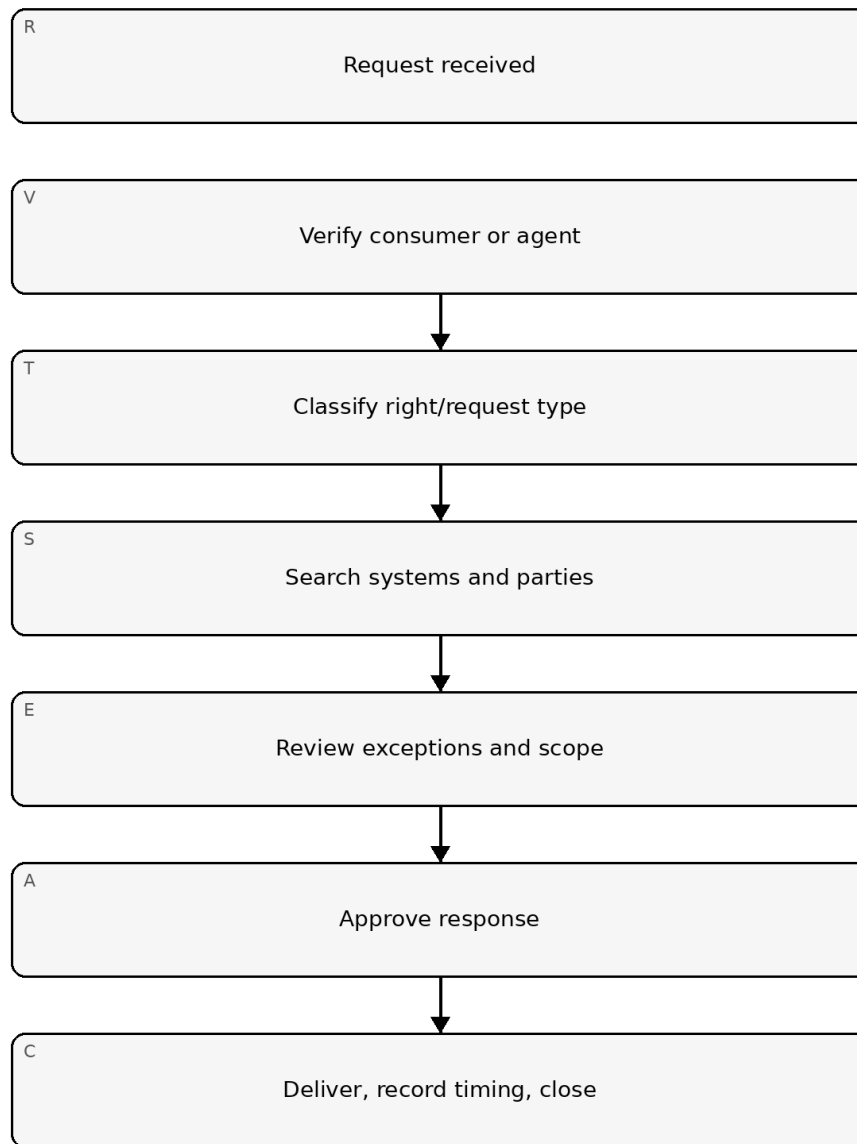


Figure 2. California privacy implementation memory graphic

Accessible explanation: A request should be validated, classified, searched across relevant systems and downstream parties, reviewed for applicable exceptions or scope limits, approved by accountable personnel, delivered within the applicable timing requirements, and closed with evidence.

2026–2028 phased-regulation timeline

Manual 12 memory graphic 3

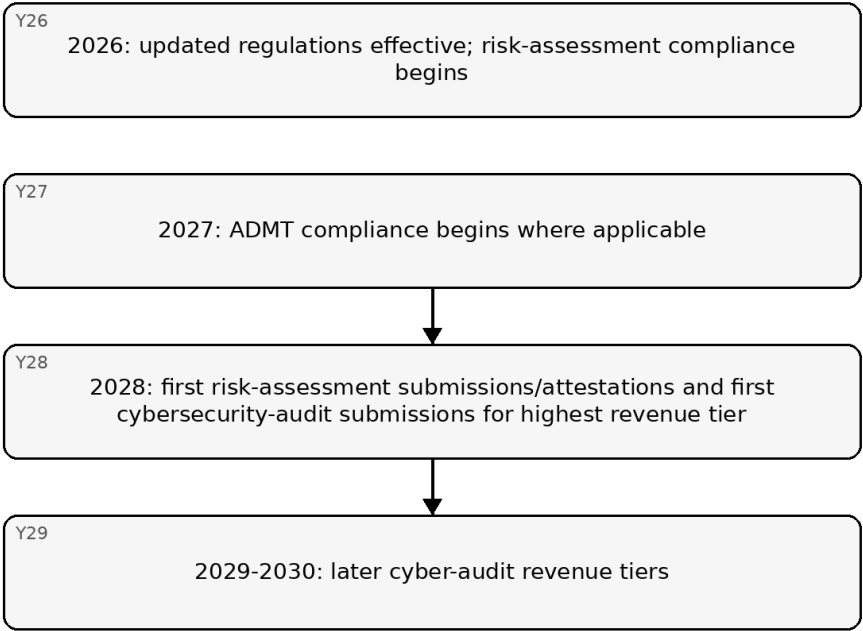


Figure 3. California privacy implementation memory graphic

Accessible explanation: Updated CCPA regulations are effective in 2026, but some compliance dates are phased. Risk-assessment obligations begin in 2026; ADMT requirements begin in 2027 where applicable; risk-assessment submission/attestation and the first cybersecurity-audit submissions begin in 2028, with later audit tiers following. Exact applicability and dates must be reverified at the final candidate.

Fail-closed boundary

Automation may validate required records, timing fields, request workflow completeness, preference-signal tests, evidence links, and source-state labels. It cannot make final organization-specific legal conclusions on applicability, exemptions, ADMT classification, risk-assessment sufficiency, audit scope, or compliance. Human legal/privacy review and Final Human Release Approval remain mandatory.

Controlled 32-chapter manual

Chapter 01 — California privacy purpose and accountability

Establish a controlled operating model that connects California privacy requirements to accountable owners, data inventories, systems, websites/apps, advertising technologies, vendors, contracts, consumer-rights operations, risk assessments, security, ADMT, retention, evidence, and management review.

Applicability conclusions should be documented with facts, thresholds, exemptions considered, reviewer, date, assumptions, and unresolved questions.

Chapter 02 — Applicability, thresholds, and exemptions

Assess whether an entity meets the current statutory definition of a covered business and whether specific processing or data falls within an exemption or special rule. Consider revenue, data-volume, sale/sharing criteria, relationships with commonly controlled entities, California consumer scope, and the actual processing model.

Do not infer applicability from company size or location alone. Reassess after mergers, business-model changes, new data uses, advertising changes, or threshold changes.

Chapter 03 — Business, service provider, contractor, and third-party roles

Classify parties based on actual data use, contractual restrictions, purposes, instructions, downstream disclosures, and independent rights rather than labels alone.

Maintain a role register connecting each relationship to data categories, purposes, contracts, sale/sharing status, service-provider/contractor restrictions, subprocessors or downstream parties, and review triggers.

Chapter 04 — Personal information and household/device context

Inventory information that identifies, relates to, describes, is reasonably capable of being associated with, or could reasonably be linked with a consumer or household where applicable. Include online identifiers, device data, browsing behavior, geolocation, commercial information, employment-related information where covered, inferences, and linked records.

Record exclusions or deidentified/aggregate treatment with supporting evidence and re-identification restrictions where relevant.

Chapter 05 — Sensitive personal information

Identify sensitive personal information and determine which use/disclosure restrictions, notices, rights, security controls, and purpose limitations apply. Map sensitive PI to systems, purposes, recipients, access, retention, and downstream parties.

High-risk sensitive-PI processing should feed risk-assessment, security, supplier, ADMT, and incident governance.

Chapter 06 — Purpose limitation and data minimization

Define specific purposes for collection, use, retention, and sharing. Collect and use data proportionately to disclosed and compatible purposes, and perform change analysis before materially expanding use.

Minimization decisions should be reflected in field-level collection, SDK/tag configuration, analytics, advertising, retention, access, exports, training datasets, and vendor instructions where applicable.

Chapter 07 — Privacy governance and decision rights

Define responsibilities across privacy, legal, security, product, engineering, marketing, advertising, data, procurement, HR, customer support, incident response, audit, and executive leadership.

Establish escalation for applicability uncertainty, rights conflicts, sale/sharing questions, sensitive PI, minors, financial incentives, risk assessments, cybersecurity audits, ADMT, data brokers, and enforcement matters.

Chapter 08 — Foundations fail-closed gate

Do not proceed as if the California privacy program is correctly scoped when applicability is unresolved, material data flows are unknown, parties are misclassified, sensitive PI is not identified, or business owners and legal/privacy reviewers are missing.

Automation may support threshold calculations and data discovery but cannot make final applicability, exemption, or role determinations without competent human review.

Chapter 09 — Notice at collection

Provide required information at or before collection in a format appropriate to the interaction. Connect notices to actual categories collected, purposes, sensitive PI, retention, sale/sharing, and relevant rights.

Notice design should account for websites, mobile apps, offline collection, connected devices, forms, call centers, employees/applicants where covered, and other collection channels.

Chapter 10 — Privacy policy and disclosure governance

Maintain a privacy policy that accurately describes current practices and applicable consumer rights. Establish ownership, versioning, legal review, accessibility, update triggers, evidence, and synchronization with data inventories and downstream relationships.

Material changes in purposes, sale/sharing, sensitive PI, ADMT, vendors, or rights operations should trigger policy-impact review.

Chapter 11 — Consumer request intake and verification

Provide required methods for consumers to submit applicable requests and implement identity/authority verification proportionate to the request and data involved.

Maintain controls for authorized agents, household requests where applicable, minors, account and non-account contexts, suspicious requests, verification failure, and secure response delivery.

Chapter 12 — Rights to know/access and data portability

Implement search, data aggregation, category/specific-information analysis, source/purpose/recipient identification, exception review, formatting, security, approval, timing, and delivery for applicable access/know requests.

Evidence should show which systems and downstream parties were searched, limitations applied, decisions made, and when the response was delivered.

Chapter 13 — Deletion and correction

Route deletion and correction requests across relevant systems and service providers/contractors, apply documented exceptions where appropriate, validate downstream completion, and preserve evidence without unnecessarily retaining the data that should be deleted.

Correction workflows should address source-of-truth decisions, conflicting records, derived data, and re-propagation to dependent systems where required.

Chapter 14 — Sale, sharing, and opt-out preference signals

Determine whether disclosures constitute sale or sharing under the applicable California definitions and operate opt-out mechanisms accordingly. Implement recognized opt-out preference signals in a manner consistent with current regulations and the organization's processing model.

Testing should cover websites, apps, consent/choice platforms, advertising tags, SDKs, server-side flows, identity resolution, downstream parties, and post-opt-out behavior.

Chapter 15 — Sensitive PI, minors, and special choice controls

Where applicable, implement the right to limit certain uses/disclosures of sensitive personal information and required notices or mechanisms. For minors, implement age-aware opt-in and consent processes consistent with applicable requirements.

Do not use dark patterns or interface designs that materially impair consumer choice.

Chapter 16 — Financial incentives and rights fail-closed gate

Where financial incentives or price/service differences depend on personal information, maintain required notices, valuation or justification records, opt-in/withdrawal processes, and consistency with current legal requirements.

Do not pass the gate when notices materially diverge from practice, requests cannot be fulfilled end-to-end, opt-out preference signals are ignored, sensitive-PI controls are missing, or consumer choices are undermined by interface behavior.

Chapter 17 — Risk-assessment applicability and intake

Identify processing activities that trigger current California risk-assessment requirements and maintain an intake process that captures purpose, data, consumers, technology, benefits, negative impacts, safeguards, stakeholders, and decision owners.

Risk-assessment compliance is part of the current 2026 baseline where applicable. Screening decisions should be documented and revisited after material change.

Chapter 18 — Risk-assessment analysis and approval

Evaluate the relationship between processing benefits and risks to consumers using the current regulatory methodology. Document facts, assumptions, negative impacts, safeguards, alternatives, residual risk, reviewers, approval, and required follow-up.

Templates and automated scoring may support consistency but cannot establish legal sufficiency or replace accountable human review.

Chapter 19 — Cybersecurity-audit readiness

Determine whether cybersecurity-audit requirements apply and build evidence architecture before the applicable submission/certification deadline. Maintain governance for audit scope, system/data inventory, security program evidence, assessor independence, findings, remediation, and executive certification where required.

The regulations are effective in 2026, while first submission dates are phased beginning in 2028. Readiness should not be confused with a claim that a 2026 submission is already due.

Chapter 20 — Reasonable security and incident evidence

Implement reasonable security appropriate to the nature of personal information and organizational risk. Connect access control, vulnerability management, configuration, encryption or equivalent safeguards, monitoring, incident response, resilience, testing, supplier security, and remediation to evidence.

Where the statutory private right of action may apply to qualifying security incidents, preserve facts and evidence for competent legal review without making automated liability conclusions.

Chapter 21 — ADMT inventory and significant-decision screening

Inventory automated decisionmaking technologies and identify purposes, inputs, outputs, affected consumers, human involvement, decisions influenced, vendors, models, data sources, risks, and change history.

Determine whether a use falls within applicable ADMT rules and significant-decision concepts through controlled legal/privacy review. Do not assume every algorithm is covered or that every human-in-the-loop design is exempt.

Chapter 22 — ADMT pre-use notice, access, and opt-out readiness

Where applicable, design pre-use notices, consumer access information, opt-out processes, exception handling, downstream enforcement, testing, evidence, and change management for ADMT.

ADMT compliance begins January 1, 2027 where applicable. Manual 12 must teach 2026 readiness without misrepresenting future obligations as already due.

Chapter 23 — Service providers, contractors, and third parties

Govern downstream relationships through role classification, required contractual restrictions, purpose/use limitations, security, consumer-right assistance, deletion/correction propagation, audit/testing rights where applicable, sale/sharing controls, subcontracting, retention, and material-change review.

Contract labels must match actual operational behavior and data use.

Chapter 24 — Risk/security/ADMT fail-closed gate

Do not pass the gate when required risk assessments are absent or unsupported, cybersecurity-audit applicability is ignored, material security weaknesses lack ownership, ADMT uses are not inventoried, or future compliance dates are represented inaccurately.

Automation may support inventory, evidence collection, testing, and deadlines; it cannot make final legal conclusions on risk-assessment sufficiency, audit applicability, ADMT coverage, or liability.

Chapter 25 — Retention, deletion, and data-quality operations

Define retention by purpose, category, system, downstream party, legal/business need, and evidence requirement. Implement deletion, archival, exception/legal-hold, backup, derived-data, and validation processes that align with disclosed purposes and minimization requirements.

Retention periods should be explainable and periodically reviewed rather than defaulting to indefinite storage.

Chapter 26 — Advertising, measurement, and identity ecosystems

Map pixels, SDKs, cookies, server-side events, clean rooms, identity-resolution services, measurement providers, data partners, and advertising platforms to data categories, purposes, sale/sharing analysis, contracts, opt-out behavior, sensitive-PI handling, and retention.

Technical testing should verify actual network and server-side behavior after consumer choices.

Chapter 27 — Data brokers and DROP distinctions

Determine separately whether data-broker registration or Delete Act/DROP obligations apply. Maintain registration, disclosure, deletion-request, identity matching, downstream deletion, exception, evidence, and audit-readiness processes where relevant.

Do not apply data-broker/DROP duties mechanically to all businesses, and do not omit them when a covered data-broker operation exists.

Chapter 28 — Recordkeeping and evidence

Maintain decision and operating evidence for applicability, notices, consumer requests, verification, opt-out preference signals, sensitive PI, contracts, risk assessments, cybersecurity-audit readiness, ADMT, retention, data brokers, incidents, training, testing, and corrective actions.

Evidence should be attributable, current, scoped to actual processing, and protected from inappropriate alteration.

Chapter 29 — Training and operational competence

Provide role-based training for privacy, legal, marketing, advertising, product, engineering, security, procurement, customer support, HR, analytics/data, audit, and leadership. Training should include realistic California-specific scenarios and common implementation errors.

Track completion, recurring defects, lessons from consumer requests and incidents, and changes in behavior where measurable.

Chapter 30 — Enforcement and regulatory-response readiness

Maintain an organized evidence package and escalation process for CPPA or Attorney General inquiries, audits, investigations, complaints, or enforcement actions. Preserve relevant facts, decisions, communications, technical evidence, contracts, risk assessments, security records, and remediation.

Regulatory responses require coordinated competent legal/privacy review and accurate representations of current and historical practice.

Chapter 31 — Assurance, metrics, and corrective action

Assess whether California privacy controls are designed appropriately, implemented, operating, evidenced, and improved. Useful measures include request timeliness/quality, opt-out signal failures, stale notices, unreviewed data flows, unresolved risk-assessment actions, retention failures, third-party defects, ADMT inventory gaps, and recurring security issues.

Repository QA and internal testing do not certify compliance or predict regulatory outcomes.

Chapter 32 — Manual release and continuous-improvement boundary

Manual 12 closes only when source verification, the controlled 32-chapter English master, privacy/legal/technical editorial review, es-419 and pt-BR localization with human semantic review, graphics/accessibility review, DOCX/PDF publication QA, repository/workflow security review, manifest/checksums/provenance, exact-head changed-scope reconciliation, and Final Human Release Approval are complete for the same exact candidate.

Completion establishes a reviewed implementation and training baseline. It does not provide organization-specific legal advice, guarantee CCPA compliance, determine liability, or replace competent legal/privacy professionals or regulators.